HOCHSCHULE MAINZ
Wirtschaft
Business

Cyber-Bedrohungen und Resilienzstrategien

Cyber Security Management · Termin 4

Prof. Dr. Dirk Loomans

University of
Applied Sciences

Agenda

- Rückblick & Lernziele
- Einstieg: Die eigene Hochschule offline
- Resilienz ist relational – sechs Bedrohungsklassen
- Ransomware · DDoS · RZ- und Dienstleister-Ausfall
- Identity-Ausfall · Human Failure · Supply Chain
- Kommunikation, wenn die eigene IT schweigt
- Mapping: Threat → Capability
- Übung: Threat-to-Resilience-Mapping
- Kernpunkte & Ausblick

Rückblick Sitzung 3

- Vier technische Prinzipien: **Redundanz, Diversität, Wiederherstellbarkeit, Adaptivität**
- Redundanz schützt nicht vor Common-Mode-Failures (CrowdStrike 2024)
- Recovery ist eine Fähigkeit, kein Dokument (Rackspace 2022)
- In Hybridarchitekturen sitzt der SPOF oft in der Steuerungsebene (Facebook 2021)

Bisher ging es um Fehler. Heute kommt der Gegner dazu.



Lernziele

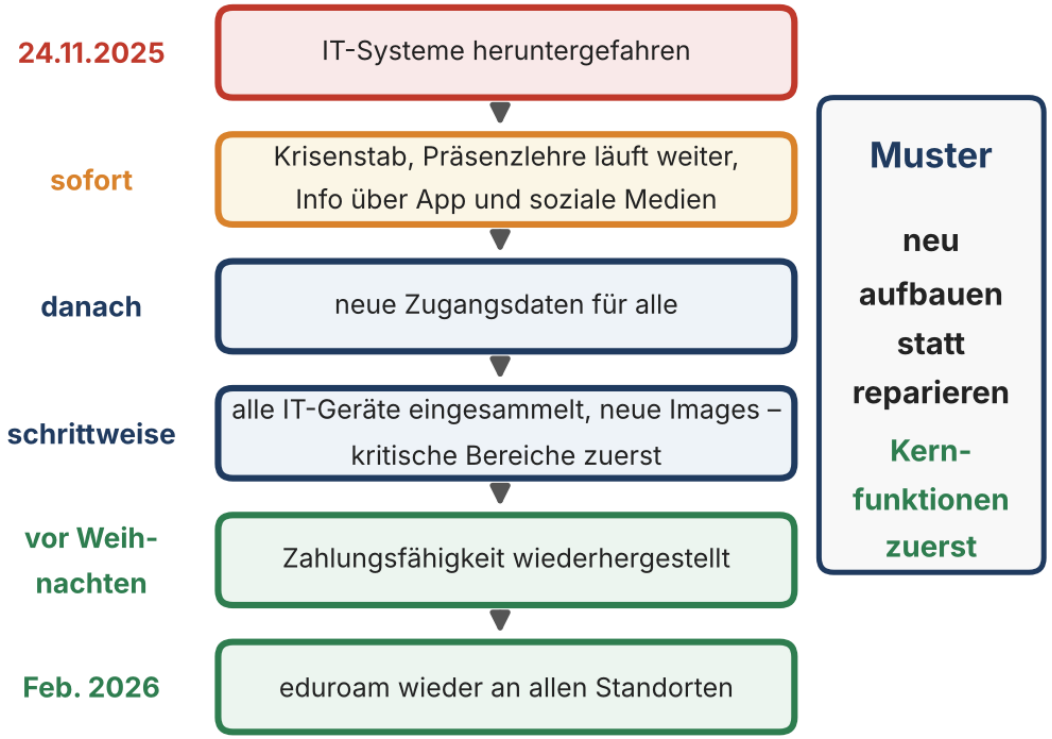
Nach dieser Sitzung können Sie …

– erklären, warum Resilienz **relational** ist – resilient *gegen etwas*,
– sechs **Bedrohungsklassen** nach ihrem Wirkmechanismus unterscheiden,
– jeder Bedrohung die **Resilienzprinzipien** zuordnen, die ihren Effekt absorbieren (Threat → Capability),
– an realen Fällen begründen, warum **Dienstleister und Identität** versteckte Single Points of Failure sind,
– die **vorsorgliche Abschaltung** und die **Notkommunikation** als Resilienzentscheidungen bewerten.

Einstieg: Die eigene Hochschule offline

- **24. November 2025:** Die Hochschule Mainz fährt nach einem Cyberangriff ihre IT-Systeme herunter
- E-Mail nur eingeschränkt nutzbar, Ermittlungsbehörden eingebunden, **Krisenstab** eingerichtet
- Die **Präsenzlehre läuft weiter**; informiert wird über Campus2Go-App, Instagram und LinkedIn
- Wiederaufbau Schritt für Schritt: neue Zugangsdaten, **alle Geräte neu aufgesetzt**, kritische Bereiche zuerst

Frage: Was hat in diesen Wochen funktioniert – und warum?

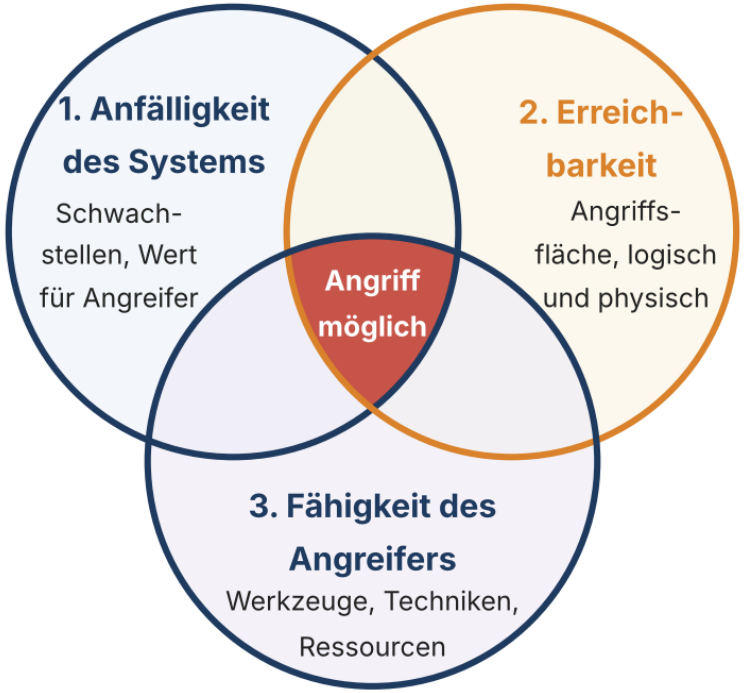


Resilienz ist relational

- Ein System ist nie „resilient an sich“, sondern **resilient gegen etwas**.
- Ohne Bedrohungsbezug bleiben Maßnahmen im Leeren.
- Das Mapping Bedrohung → Fähigkeit schafft **Priorisierung und Budgetfokus**.
- Ziel ist nicht Prävention, sondern **Funktionsfähigkeit trotz realer Ereignisse**.

Nicht die Bedrohung wird kontrolliert, sondern die Fähigkeit, ihren Effekt zu absorbieren.

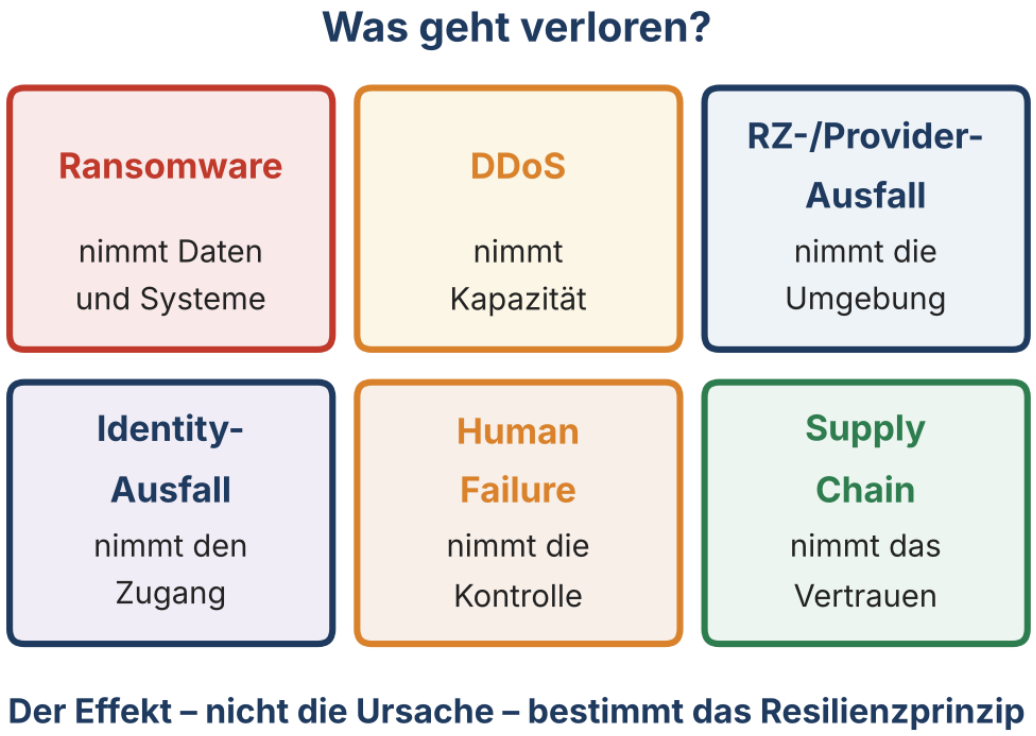
Resilienz fragt weiter: Was passiert, wenn der Angriff gelingt?



Sechs Bedrohungsklassen

Entscheidend ist der **Wirkmechanismus**, nicht die Ursache:

- **Ransomware** zerstört Daten und Systeme
- **DDoS** verbraucht Kapazität
- **RZ- und Provider-Ausfall** nimmt die Umgebung
- **Identity-Ausfall** nimmt den Zugang
- **Human Failure** propagiert Fehler über Automatisierung
- **Supply Chain** importiert fremde Kompromittierung



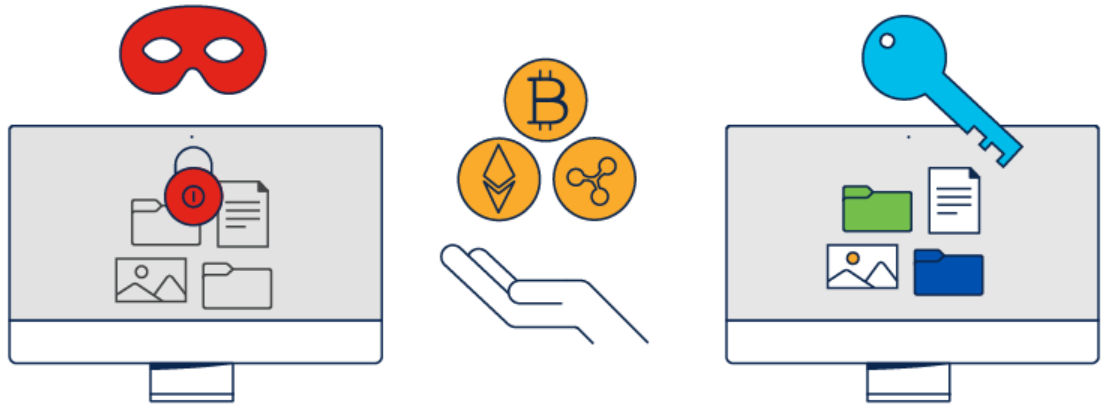
Bedrohung 1: Ransomware

Wirkprinzip: Verschlüsselung, Löschung oder Sabotage – bei seitlicher Ausbreitung auch von Replikaten und Backups

Resilienzstrategien (nicht Prävention!)

– Immutable- und Offline-Backups außerhalb des Blast Radius
– Netzwerk- und Domain-Segmentierung
– Gold-Images und **Clean-Room-Recovery**
– Recovery-Tests statt Papierpläne

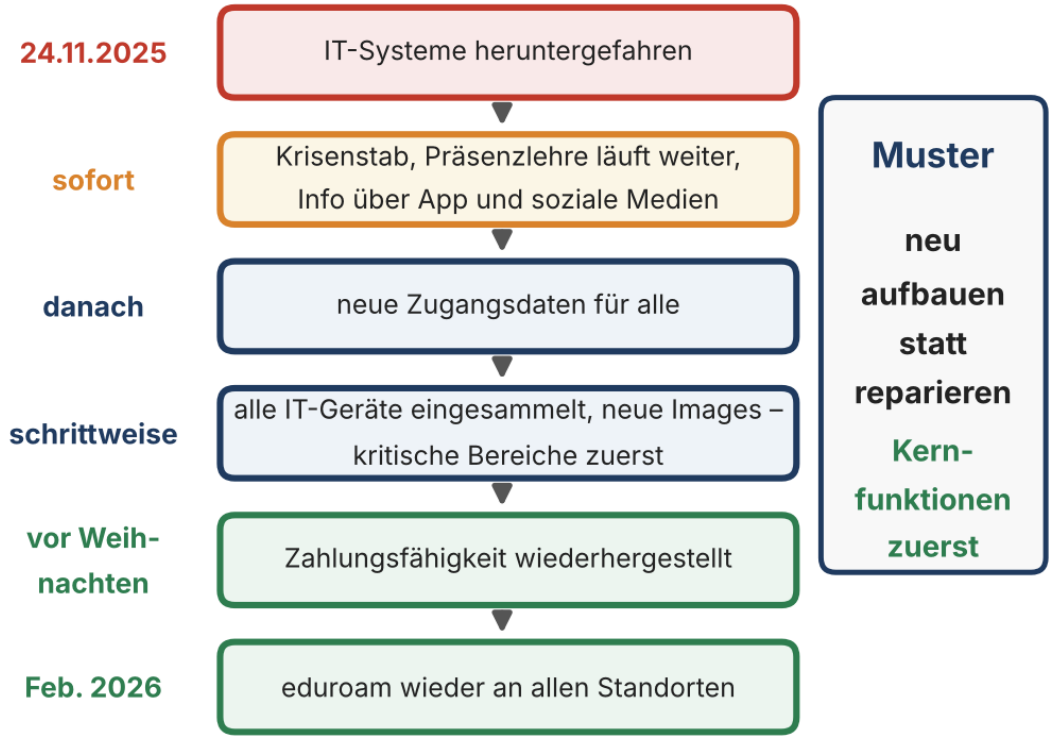
Zielgröße: RTO und RPO niedrig halten – trotz kompromittierter Produktion



Fallbeispiel: Wiederaufbau an der Hochschule Mainz

- **Neue Zugangsdaten** für alle Beschäftigten, Lehrenden und Lehrbeauftragten
- **Alle IT-verwalteten Geräte** eingesammelt und mit neuen System-Images ausgerollt
- **Priorisierung:** systemrelevante Bereiche zuerst, dann die übrigen Abteilungen
- Zahlungsfähigkeit **vor Weihnachten**, eduroam im Februar 2026 wieder an allen Standorten
- Viele Abläufe laufen über **Monate** mit höherem organisatorischem Aufwand

Neu aufbauen statt reparieren – das ist Clean-Room-Recovery.



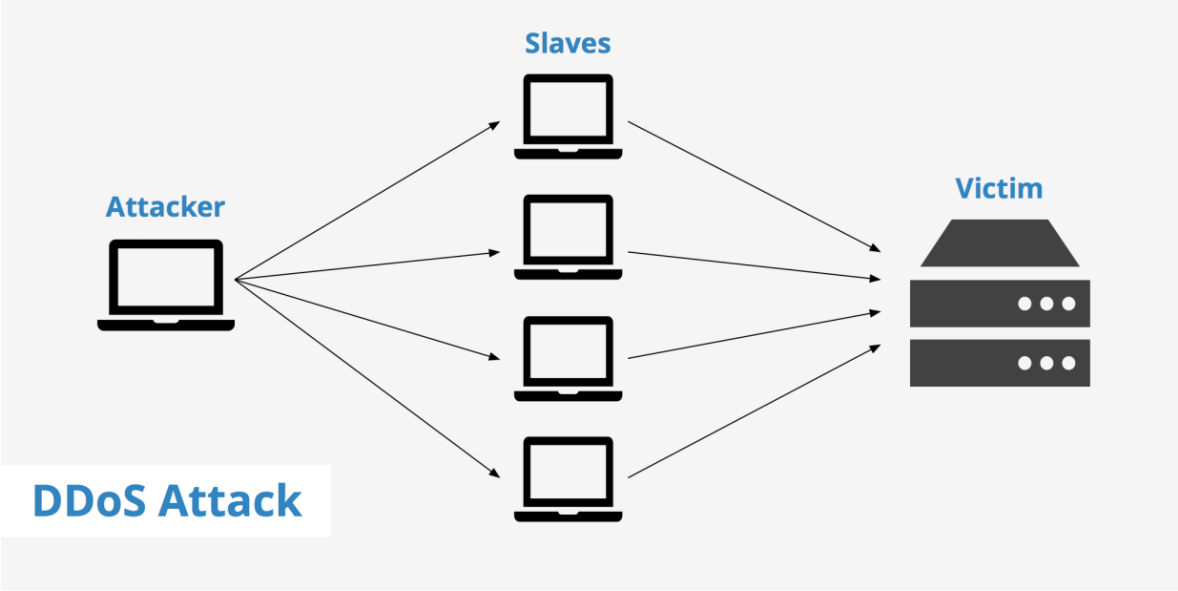
Bedrohung 2: DDoS und Lastangriffe

Wirkprinzip: Der Dienst ist technisch intakt, aber nicht mehr nutzbar – Ressourcen werden schneller verbraucht, als sie bereitstehen

Resilienzstrategien

– Anycast-CDN und Traffic-Scrubbing
– Auto-Scaling und Rate-Limiting
– Graceful Degradation – nicht alles oder nichts
– API-Quotas und Circuit Breaker

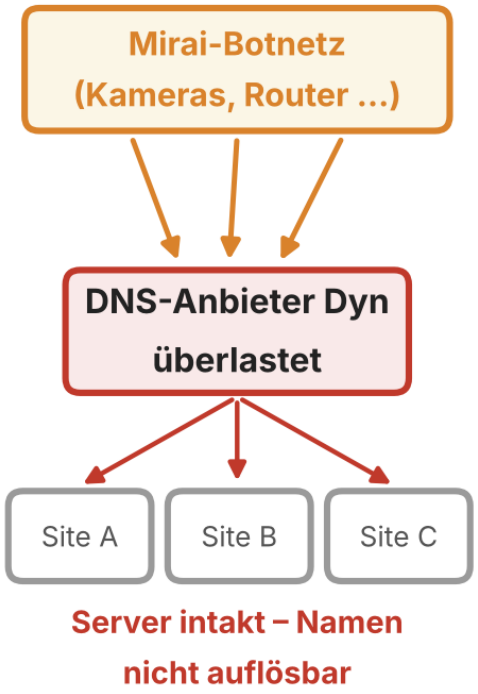
Ziel: Dienst bleibt nutzbar – nicht perfekt, aber funktional

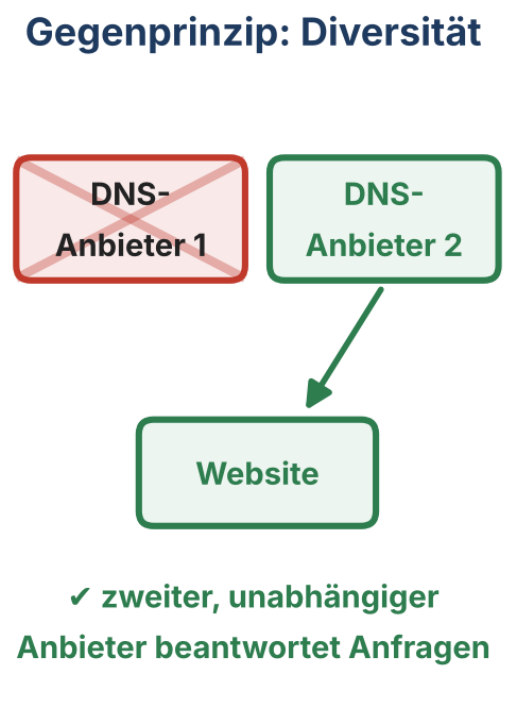


Fallbeispiel: Dyn und das Mirai-Botnetz 2016

- **21. Oktober 2016:** Zwei Angriffswellen treffen den DNS-Anbieter Dyn, vor allem an der US-Ostküste
- Hauptquelle: das **Mirai-Botnetz** aus gekaperten IoT-Geräten – Dyn schätzt bis zu **100.000** Endpunkte
- Dienste wie Twitter, Spotify und Reddit sind für viele Nutzer **nicht erreichbar**
- Die Webserver selbst sind intakt – nur ihre **Namen lassen sich nicht auflösen**

Wer nur einen DNS-Anbieter hat, teilt dessen Schicksal.





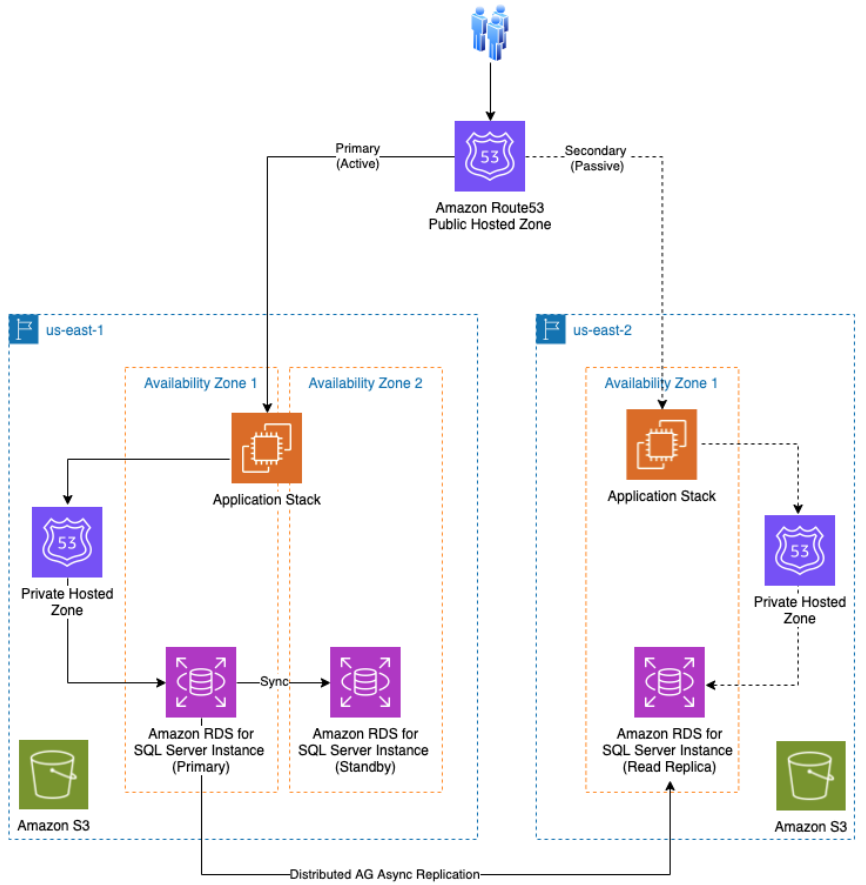
Bedrohung 3: Rechenzentrums- und Dienstleister-Ausfall

Wirkprinzip: Die Umgebung fällt von außen weg – Redundanz auf Anbieterebene bricht

Resilienzstrategien

– Multi-AZ- und Cross-Region-Deployment
– Multi-Cloud oder zweiter Betreiber für kritische Workloads
– lokaler Fallback für die Mindestfunktion
– Trennung von Steuer- und Ausführungsdomäne

Lehrsatz: Provider ≠ Resilienz – Architektur und Vertrag entscheiden



Fallbeispiel: KDZ Mainz und KGRZ Koblenz 2026

- **27.09.2026:** Die kommunalen Rechenzentren in Mainz und Koblenz schalten zentrale Fachverfahren **vorsorglich ab** – wegen kritischer Lücken in Citrix NetScaler
- Betroffen: alle **194** hauptamtlichen Verwaltungen in Rheinland-Pfalz – Meldeamt, Kfz-Zulassung, Standesamt u. a. stehen still
- **29.09.:** nach Updates und Prüfung wieder in Betrieb, laut Betreibern kein erfolgreicher Angriff

Ein gemeinsamer Dienstleister bündelt Effizienz – und das Ausfallrisiko.



Abschalten als Resilienzentscheidung

- **Weiterlaufen:** Dienst verfügbar, aber unbekanntes Risiko – Einbruch, Datenabfluss, wochenlanger Wiederaufbau
- **Abschalten:** geplanter Ausfall mit **absehbarer Dauer** – der Angreifer kommt nicht hinein
- Voraussetzung: ein **vorbereiteter Notbetrieb** und klare Entscheidungsrechte
- **Stadt Mainz, 21. Oktober 2026:** wegen einer kritischen PHP-Lücke Website vom Netz – Ämter, Telefon und E-Mail laufen weiter

Ein kontrollierter Ausfall ist besser als ein unkontrollierter.



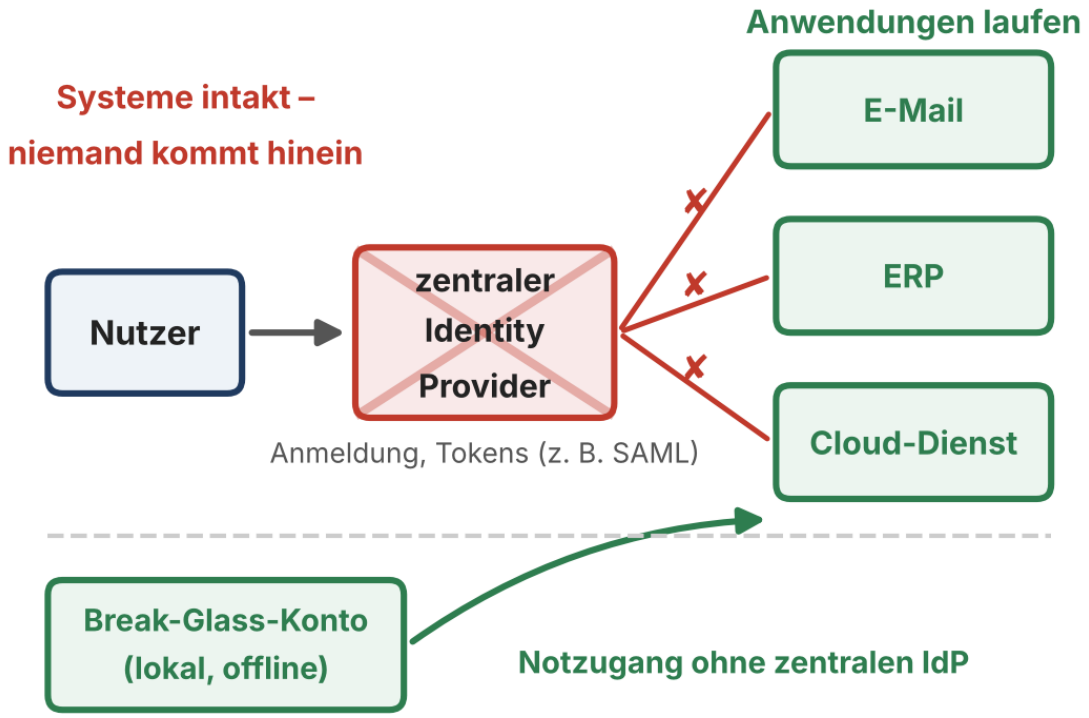
Bedrohung 4: Identity-Ausfall

Wirkprinzip: Systeme laufen – aber niemand kommt hinein (Lockout)

Resilienzstrategien

– Break-Glass-Accounts, lokal und offline
– zweiter unabhängiger IdP oder Fallback-Authentisierung
– Notfallzugang ohne Cloud-Abhängigkeit
– Minimierung globaler Koppelstellen

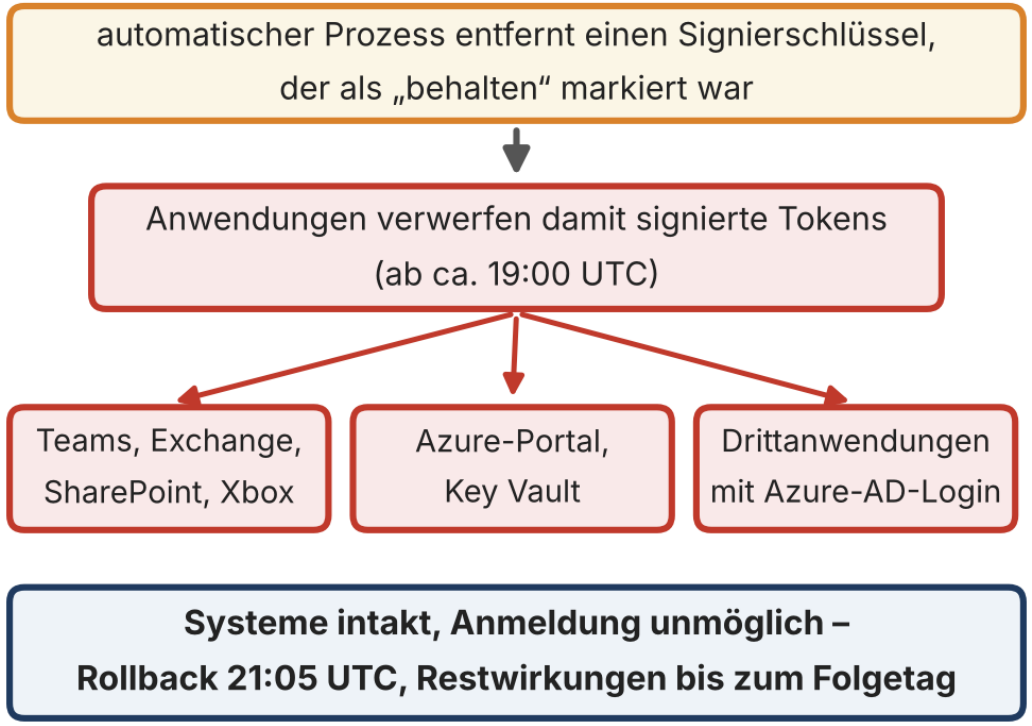
Kernaussage: Identity ist oft der versteckte Single Point of Failure



Fallbeispiel: Azure AD 2021

- **15. März 2021, abends:** Ein automatischer Prozess entfernt einen Signierschlüssel, der als „behalten“ markiert war
- Anwendungen verwerfen damit signierte Tokens – Anmeldungen scheitern
- Betroffen: Teams, Exchange, Azure-Portal, Xbox und **Drittanwendungen** mit Azure-AD-Login
- Rollback nach rund zwei Stunden, Restwirkungen bis zum nächsten Morgen
- Die **Backup-Authentisierung half nicht**: Sie deckte nur die Ausgabe von Tokens ab, nicht ihre Prüfung

Alles lief – nur der Zugang nicht.



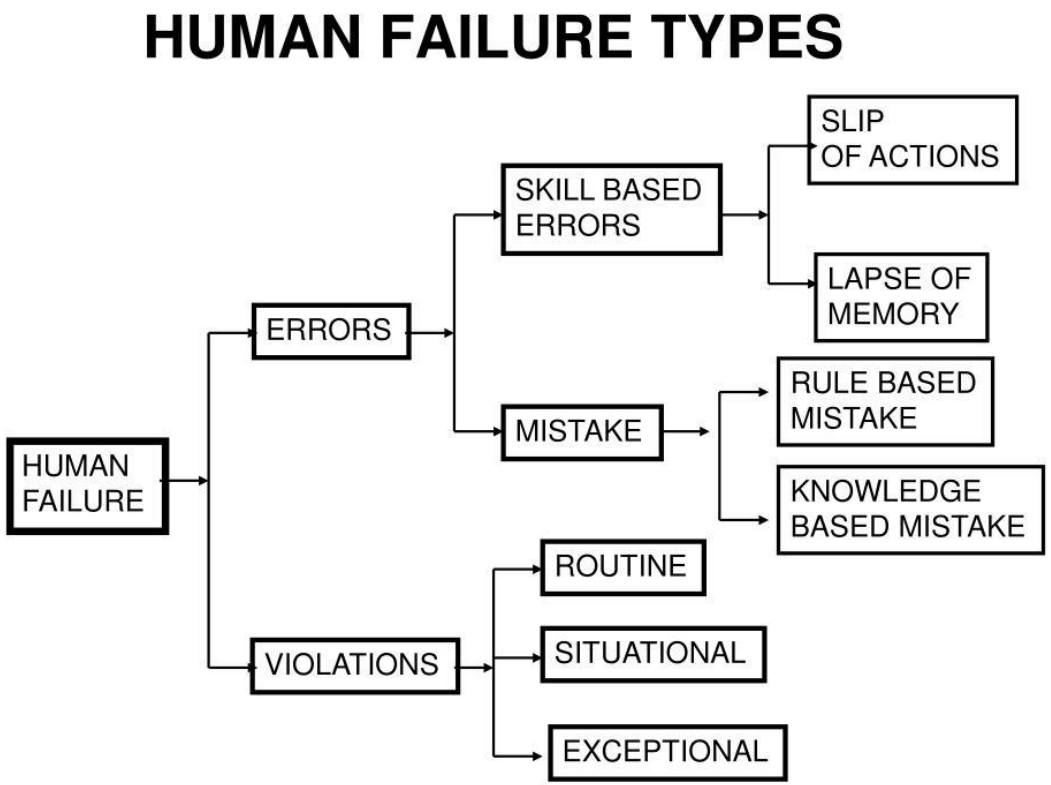
Bedrohung 5: Human Failure und Fehlkonfiguration

Wirkprinzip: Ein lokaler Fehler wird über Automatisierung systemisch (IaC, CI/CD, Admin-Werkzeuge)

Resilienzstrategien

- Vier-Augen-Prinzip und Separation of Duties
- Staging, Canary Deployment, Feature Flags
- Rollback- und Snapshot-Fähigkeit
- **Leitplanken im Werkzeug** und Post-Mortem-Kultur statt Schuldsuche

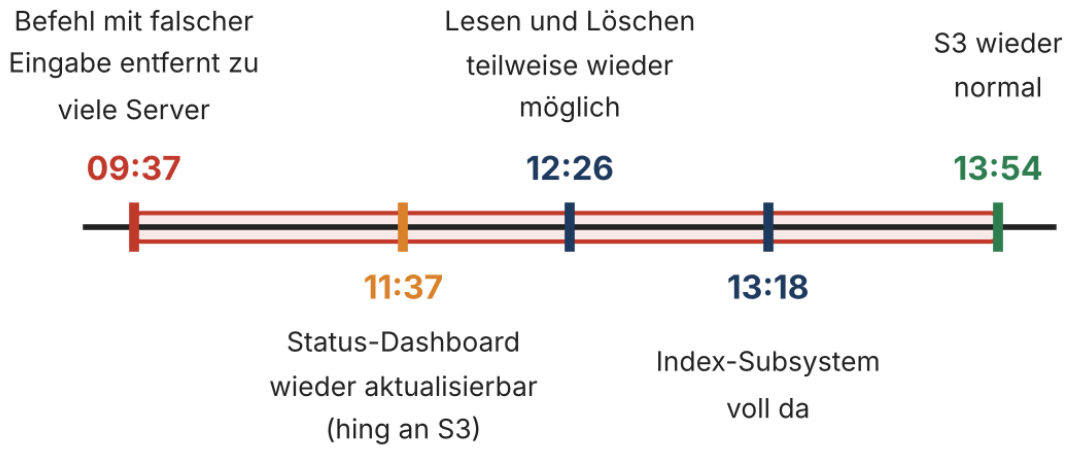
Prinzipbezug: Wiederherstellbarkeit und Governance



Fallbeispiel: AWS S3 2017

- **28. Februar 2017:** Ein Techniker will per Befehl wenige Server eines S3-Teilsystems entfernen – **eine Eingabe ist falsch**
- Es fallen deutlich mehr Server weg; zwei Kernsubsysteme müssen **komplett neu starten**
- S3 in us-east-1 ist gut **vier Stunden** gestört, abhängige Dienste mit
- Pointe: Auch das **Status-Dashboard** hing an S3 und zeigte lange nichts an

AWS änderte das Werkzeug, nicht nur die Schulung.



Konsequenz: Werkzeug entfernt langsamer und nie unter Mindestkapazität – Leitplanken statt Schuldzuweisung

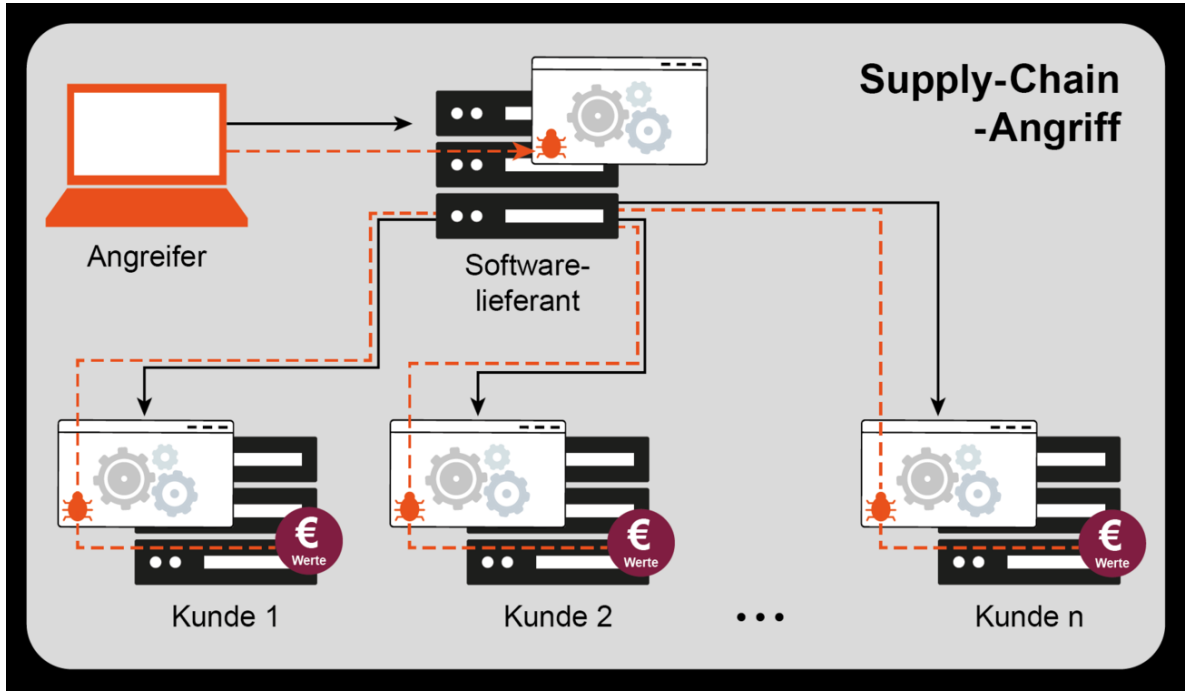
Bedrohung 6: Supply-Chain-Angriff

Wirkprinzip: Die Kompromittierung kommt über Dritte in die eigene Umgebung – über Software, Updates oder Dienstleister

Resilienzstrategien

- Lieferantendiversität, keine Monokultur in kritischen Abhängigkeiten
- Zero Trust for Dependencies
- kein Auto-Push bei kritischen Komponenten, Offline-Verifikation
- Recovery **unabhängig vom kompromittierten Lieferanten**

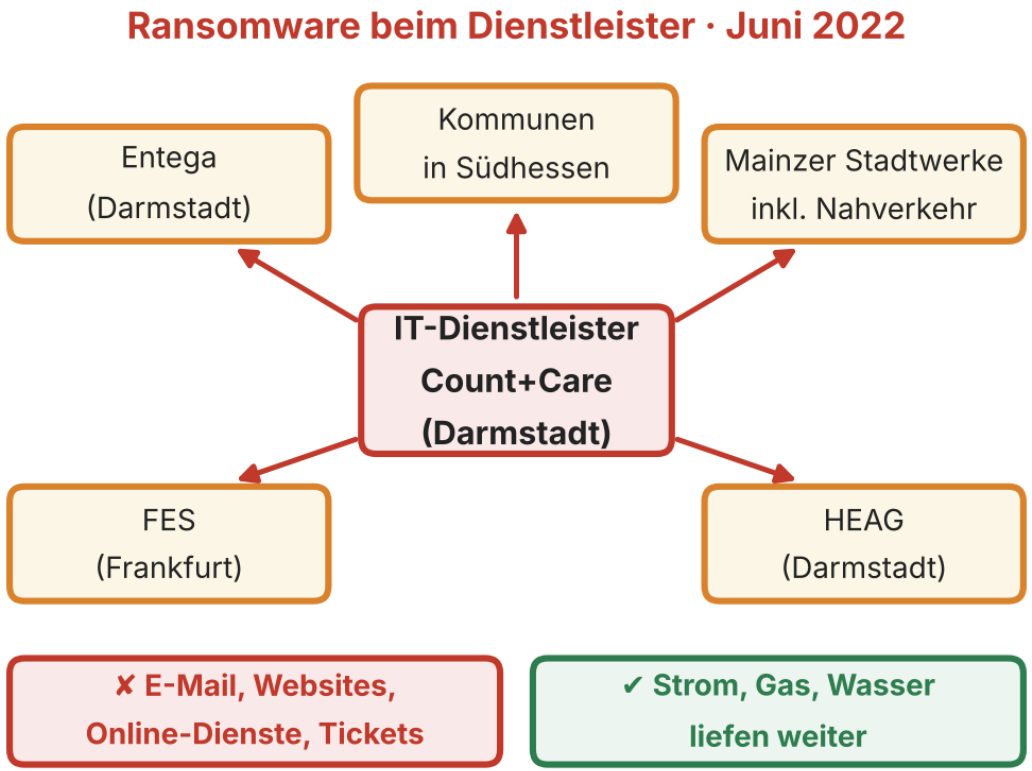
Lehrsatz: Resilienz ist das Sicherheitsnetz nach dem Vertrauensbruch



Fallbeispiel: Count+Care und die Mainzer Stadtwerke 2022

- **Juni 2022:** Ransomware-Angriff auf Count+Care, den IT-Dienstleister der Entega in Darmstadt
- Mitbetroffen: **Mainzer Stadtwerke** samt Nahverkehr, FES Frankfurt, HEAG, Kommunen in Südhessen
- Websites und E-Mail-Konten tausender Beschäftigter fallen aus; im Nahverkehr Ausfälle und eingeschränkter Ticketverkauf
- **Strom, Gas und Wasser laufen weiter**
- Im Juli veröffentlichen die Täter Kundendaten der Entega

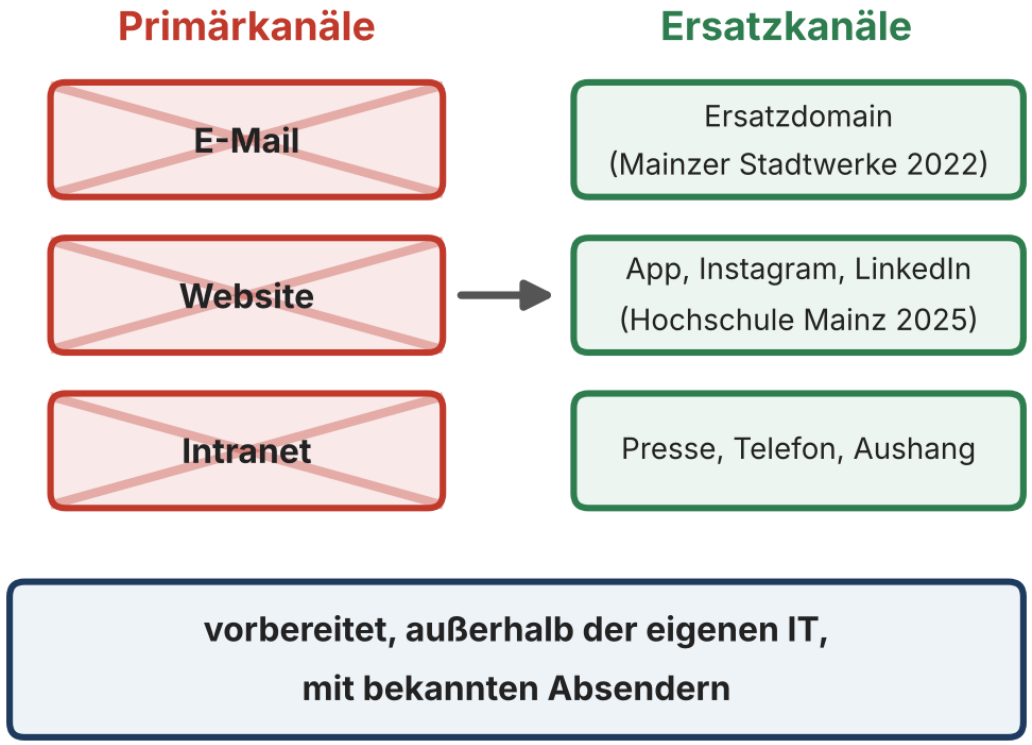
Der Angriff traf einen – ausgefallen sind viele.



Kommunikation, wenn die eigene IT schweigt

- Wer die eigene IT verliert, verliert meist auch **E-Mail, Website und Intranet**.
- **Mainzer Stadtwerke 2022:** neue Website unter Ersatzdomain und neue Kontakt-Mailadressen innerhalb weniger Tage
- **Hochschule Mainz 2025:** Information über App, Instagram und LinkedIn
- **AWS 2017:** Status über Twitter, weil das Dashboard selbst ausgefallen war

Notkommunikation ist eine Resilienzfähigkeit – sie muss vorbereitet sein, bevor sie gebraucht wird.



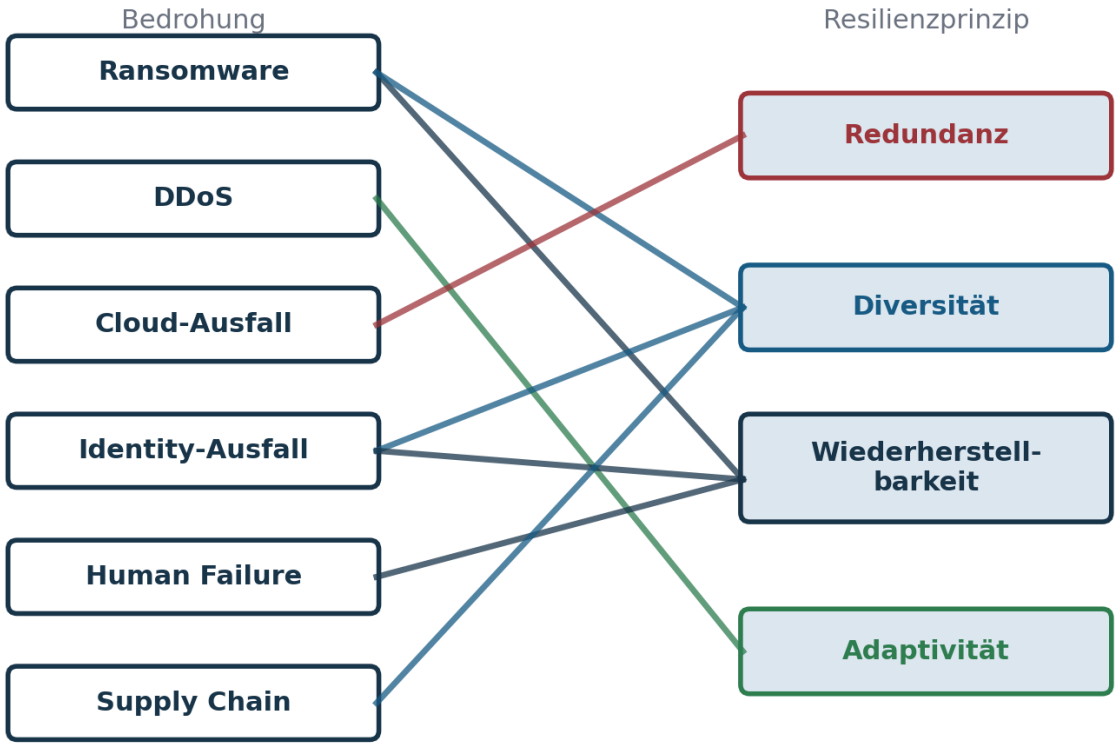
Framework-Abgleich: Threat → Resilience Capability

Die Bedrohung entscheidet nicht über das Tool, sondern über das Prinzip.

Bedrohung	Resilienzprinzip	Fall	Normativer Bezug
Ransomware	Wiederherstellbarkeit, Diversität	HS Mainz 2025	ISO/IEC 27031 · BSI 200-4
DDoS	Adaptivität, Diversität	Dyn 2016	ENISA DDoS Guidance
RZ-/Dienstleister-Ausfall	Redundanz, Entkopplung	KDZ/KGRZ 2026	NIST SP 800-160 Vol. 2
Identity-Ausfall	Diversität, Break-Glass	Azure AD 2021	NIST CSF · Zero Trust
Human Failure	Wiederherstellbarkeit, Leitplanken	AWS S3 2017	BSI 200-4 · IT-Grundschutz
Supply Chain	Diversität, Isolation	Count+Care 2022	ENISA Supply Chain Guidance

Was das Mapping zeigt

- Verschiedene Bedrohungen adressieren **dasselbe Prinzip** (Ransomware und Human Failure → Recovery).
- Dasselbe Prinzip wirkt gegen **verschiedene Bedrohungen** (Diversität gegen DDoS-Abhängigkeit, Identity-Ausfall und Supply Chain).
- **Dienstleister und Identität** tauchen in fast allen Fällen als gemeinsamer Fehlerpfad auf.
- Nicht die Bedrohung wird kontrolliert, sondern die Fähigkeit, ihren Effekt zu absorbieren.



Übung: Threat-to-Resilience-Mapping

Gruppen, 15–20 Minuten. Wählt eine Bedrohung und einen der heutigen Fälle – oder einen eigenen Fall.

1. **Wirkmechanismus** in 1–2 Sätzen beschreiben
2. **Mindestens zwei Resilienzprinzipien** zuordnen und begründen
3. Je Prinzip **eine konkrete, realistische Maßnahme** nennen
4. **Kurzfazit:** resilient, bedingt resilient oder fragil – mit einem Satz Begründung

Ergebnis: eine Folie pro Gruppe, höchstens sechs Stichpunkte. Bewertet wird die Schärfe der Zuordnung, nicht die Menge der Maßnahmen.

Raster für die Übung

Das Raster hält die vier Schritte fest.

Wirkmechanismus	Prinzip	Maßnahme	Fazit
	1.		
	2.		

Kernpunkte

- Resilienz ist **relational** – sie bewertet sich immer gegen eine konkrete Bedrohung.
- Sechs Bedrohungsklassen, unterschieden nach dem **Effekt**, nicht nach der Ursache.
- Nach Ransomware heißt Recovery **Neuaufbau** – mit Kernfunktionen zuerst (Hochschule Mainz).
- **Dienstleister, DNS und Identität** sind gemeinsame Fehlerpfade vieler Organisationen (KDZ/KGRZ, Count+Care, Dyn, Azure AD).
- Vorsorgliches Abschalten und Notkommunikation sind **Resilienzentscheidungen**, die vorbereitet sein müssen.

Ausblick & Hausaufgabe

Nächste Sitzung: Resilienz als Organisationsfähigkeit – Rollen, Prozesse, Übungen, Governance
Hausaufgabe: Stellen Sie sich vor, Ihre Organisation (Hochschule, Arbeitgeber, Verein) verliert morgen E-Mail und Website. Über welche Kanäle erfahren die Betroffenen davon – und wer entscheidet, was kommuniziert wird?
Kapitel zum Termin · Skript · Glossar · Quellen